OWASP Compliance Evidence — 80% Milestone

Document control

Forever Hotel • Manager Dashboard • Guide deliverable 8

Prepared: 2026-10-25, Asia/Colombo. Snapshot: development, caef8822afc0c44b030bea2453e23eb01d4af42a. Gateway: separate repository commit b0329c15ee0a686a0de9e62a93d856d4f7df8e8d. Owner/student identity and security reviewer approval: not supplied.

Assessment type: source/control review with historical observations, not an executed penetration test or an OWASP certification. Approximate project progress is 80% as declared by the owner, not a measured compliance score. No fresh dependency, secret, dynamic application or infrastructure scan was run to prepare this report.

1. Boundary and guide interpretation

This report applies to MAD and the supporting routing gateway. It does not certify guest login, Stripe, KOT printing or the complete HW/FDS/FOSS/KMS/WKMS deployments. The guide section 8.1 A01–A10 categories are used as the checklist baseline. Unfinished provider, hardening, testing and acceptance work is explicitly pending.

The remaining project work is not hidden to produce an artificial “80% compliant” result. Known failures or deviations remain in the checklist because they materially affect the safety of the implemented 80%-milestone scope.

2. Assets, trust boundaries and threats

Asset / boundary	Main threat	MAD control or remaining review
Manager browser BFF	Cookie theft, CSRF, stale session, unauthorized route access	HttpOnly cookie, same-origin/Origin handling, session boundary; production browser/security review pending
BFF gateway MAD	Forged bearer tokens, untrusted paths, excessive requests	Gateway transport limits and canonical paths; backend JWT/account checks
MAD shared Neon	SQL injection, excessive grants, concurrent overwrite, source ownership breach	Bound parameters, transactions/version checks; actual restricted-role grants not verified
Credential delivery queue SendGrid	Leaked temporary passwords, retry replay, exposure in responses/logs	AES-256-GCM queue payload, worker delivery state; verified sender/inbox and email-security interpretation pending

Asset / boundary	Main threat	MAD control or remaining review
Producers RabbitMQ MAD	Poison messages, duplicates, reordering, forged source changes	Validated contracts, source rereads, durable inbox/version state and retries; producer/broker privilege agreement pending
Browser direct MAD socket	Ticket replay, wrong Origin, expired/ deactivated account, replica mismatch	One-use 30-second ticket and auth rechecks; process-local storage limits multi-instance use
Build configuration / CI	Executable configuration injection and compromised dependencies	Lockfiles, reviewed build-config hashes, integrity regression source, audits; host forensic closure not established
Logs / exports	PII leakage, formula injection, unbounded export resource use	Safe projections/errors, CSV neutralization, output bounds; logging/retention and live access audit pending

3. OWASP A01–A10 evidence summary

Risk	Guide mitigation	Source-review assessment	Final acceptance
A01 Broken Access Control	Role checks; unauthorized access tests	Manager guards and session checks implemented; other-role/ provider grants need review	Partial; not penetration-tested
A02 Cryptographic Failures	bcrypt cost 12, token hashing, TLS	Staff bcrypt12, manager scrypt, hashed revocation IDs, queue encryption, Neon TLS	Partial; guide password deviation and production TLS pending
A03 Injection	Parameterized queries; validated input	Bound SQL, DTO whitelist, bounded filters and output escaping	Controls inspected; execution proof pending
A04 Insecure Design	Threat model and design review	Trust-boundary analysis and transactional/versioned policies present	Peer/provider design approval pending
A05 Security Misconfiguration	No default credentials or stack disclosure	Environment validation, safe errors, unprivileged/ read-only gateway	Production exposure/ secrets/grant review pending
A06 Vulnerable Components	CI scan; no high/critical advisories	Audit gates exist; prior gateway advisories and frontend exception recorded	Unresolved; fresh scan/ remediation required

Risk	Guide mitigation	Source-review assessment	Final acceptance
A07 Auth Failures	Lockout and secure session management	Database lockout, expiry, versions, revocation and forced change	Controls inspected; auth compatibility and live test pending
A08 Integrity Failures	Lockfiles and pipeline integrity	Frontend config hashes, ignored install scripts in frontend/gateway, event versions	Host/build-chain closure not established
A09 Logging Failures	Auth/error/data-access logs without PII/secrets	Structured telemetry and safe projections exist	Completeness/redaction/ retention not verified
A10 SSRF	URL validation and allowed domains	Validated configured upstream origins, canonical paths and redirect limits	Generic config is not an independently verified network allowlist

No category is marked fully compliant without current execution and environment evidence. A01 should distinguish missing/invalid authentication (401) from valid but unauthorized access (403); a role check cannot be assessed solely by expecting the same status for both situations.

4. Detailed control evidence and required checks

A01 — Broken Access Control

Backend JwtAuthGuard calls the auth service and attaches a verified manager session. The service checks active staff state, role, required password change, session version and revocation. Frontend protection is an additional UI boundary; backend authorization remains necessary even if the browser bypasses that UI. MAD is read-only for WKMS task mutations and KMS operational source changes.

Evidence: backend/src/auth/jwt-auth.guard.ts, backend/src/auth/auth.service.ts, frontend/proxy.ts, backend/src/common/security-boundaries.spec.ts, backend/test/tasks.e2e-spec.ts. Required live checks: direct API bypass, wrong role, deactivated/expired/revoked sessions, object access, private complaint history and actual DB grants. SDS partial Kitchen Manager access is not implemented by the MANAGER-only session model; provisioning that role does not grant MAD access.

A02 — Cryptographic Failures

Staff provisioning/reset uses bcrypt cost 12. Manager initial-login/password-change uses salted scrypt with N=32768, r=8, p=3. This is a format/design deviation from the guide/SDS bcrypt requirement and must be approved or aligned; it must not be reported as bcrypt compliance. Cross-subsystem hash compatibility needs agreement.

Logout stores a token hash in mad_revoked_sessions; the report does not claim that every possible token is persisted only as a hash. The login token is carried in an HttpOnly frontend cookie and held server-side while forwarding. Queued staff credentials use AES-256-GCM with a separate configured key. This protects the queue, not every staff/guest column or every downstream email mailbox.

Evidence: backend/src/auth/password.ts, backend/src/staff/staff.service.ts, backend/src/staff/credential-cipher.ts, backend/src/database/connection.ts. Production HTTPS/WSS, key rotation/storage, backup encryption and the meaning of encrypted credential email remain unverified. Local HTTP/AMQP is development setup.

A03 — Injection

Reporting and mutations use bound SQL parameters. DTO validation rejects unknown fields, invalid UUIDs, malformed dates and unsupported enum/filter values. Report rendering quotes/neutralizes CSV formula prefixes and bounds output size. Source inspection does not replace SQL/XSS/formula-injection execution tests.

Evidence: backend/src/common/http.ts, backend/src/analytics/bookings.sql.ts, backend/src/promotions/promotion.dto.ts, backend/src/reports/report-renderer.ts, backend/test/reports.e2e-spec.ts. Required checks: invalid types/ranges, stored HTML/special characters, SQL payloads and spreadsheet formula prefixes. Keep input synthetic and avoid modifying source-owned production data.

A04 — Insecure Design

Key design controls include transactional outbox/inbox state, optimistic versions, explicit complaint transitions, logical promotion deletion and requested/effective WKMS policy separation. Snapshot reloads reconcile non-durable browser delivery. This document records threats, but no independent security-design review is attached.

Evidence: backend/src/promotions/promotions.service.ts, backend/src/complaints/complaints.service.ts, backend/src/settings/task-limit.service.ts, local decisions in docs/decisions/. Remaining work: provider ownership approval, retry/replay/race tests, failure-state review and multi-instance socket/ticket design.

A05 — Security Misconfiguration

Environment validation rejects unsafe schema synchronization and invalid settings. Safe error responses hide internal failures. Gateway has a read-only root filesystem, unprivileged user, dropped capabilities and no-new-privileges in local Compose. Actual credentials are not loaded or printed by this document-generation process.

Evidence: backend/src/config/environment.ts, backend/src/common/http.ts, api-gateway/src/config.ts, api-gateway/Dockerfile, docker-compose.yml. The gateway deliberately provides routing only; absence of gateway JWT validation is not itself a bug if every protected downstream endpoint enforces its own auth. Local example broker defaults are not acceptable production secrets. Public ports, production TLS, effective permissions and host exposure require review.

A06 — Vulnerable and Outdated Components

MAD CI runs backend npm audit and a controlled frontend audit policy. Gateway CI also audits dependencies. A prior gateway audit reported high-severity Fastify advisories. No fresh scan was run here, so a current advisory count or remediation claim cannot be made. Do not label an audit configuration as a clean audit result.

The frontend policy permits only a narrow reviewed development dependency chain for advisory GHSA-vfj7-8cjw-p6xm until 2026-11-14. This is a documented exception, not satisfaction of the guide's zero-known-high/critical gate. At expiry it fails closed; it is not an allowance for unrelated production advisories.

Evidence: .github/workflows/ci.yml, frontend/scripts/audit-ci.mjs, gateway workflow and lockfile. Required handoff: dated audit output for the tested SHA, remediation/approved risk decision, dependency review and exception removal/renewal decision. Do not run forced major upgrades without compatibility review.

A07 — Identification and Authentication Failures

Initial manager creation never resets an existing account. The database tracks failed attempts/lockout and password-change requirements. Eight-hour JWT expiry, issuer/audience validation, session versions and revocation protect the lifecycle. No shared SSO, refresh-token rotation or MFA implementation is claimed.

Evidence: backend/src/auth/initial-manager.service.ts, backend/src/auth/token.service.ts, backend/src/auth/auth.service.spec.ts, frontend/test/restored-login.test.tsx. Required checks include wrong/current passwords, lockout boundaries, duplicate submission, forced change, logout/replay and account deactivation. An expired JWT is different from a measured inactivity timeout; no separate idle-session tracker is established by this review.

A08 — Software and Data Integrity Failures

The historical build-config injection was removed and reviewed configuration hashes/regression sources were added. Frontend and gateway installs disable dependency lifecycle scripts in their build paths. Backend install behavior must be reviewed separately; this report does not claim install scripts are disabled throughout every repository.

Evidence: frontend/scripts/verify-build-config.mjs, frontend/scripts/build-config-integrity.json, frontend/Dockerfile, api-gateway/Dockerfile, local incident records in docs/security/. Lockfiles/config hashes do not prove dependencies or the developer host are clean. Host forensic closure, CI permissions, protected branches and source-owner event integrity remain review items.

A09 — Security Logging and Monitoring Failures

MAD has structured operations telemetry, status reporting and safe error envelopes. Gateway emits request IDs and bounded operational metadata rather than bodies or credentials. Existing source is evidence of logging mechanisms, not proof that every authentication, error and data-access event is logged and retained correctly.

Evidence: backend/src/operations/operations.telemetry.ts, backend/src/operations/operations.service.ts, backend/src/common/http.ts, api-gateway/src/gateway.transport.ts. Validate redaction and correlation with synthetic requests. Twelve-month storage, alerting, retrieval and access controls are not proven. Earlier host retention/backup templates were removed and are not part of the delivered runtime.

A10 — Server-Side Request Forgery

The routing gateway selects configured upstream origins and validated canonical prefixes rather than accepting arbitrary browser URLs. It bounds deadlines and response bodies and handles redirects explicitly. However, accepting a configured HTTP(S) origin is not the same as enforcing an infrastructure-approved domain/IP egress allowlist under every DNS/redirect condition.

Evidence: api-gateway/src/config.ts, api-gateway/src/http.ts, api-gateway/src/gateway.transport.ts, api-gateway/test/gateway.test.ts. Required work: configuration-owner approval, private-network/metadata-address checks in the intended deployment, redirect/path tests and host egress controls.

5. Findings and remaining work register

Priorities here are review priorities, not measured CVSS scores. No actual secret or exploit payload is included.

Finding	Priority	Status / action
Prior high-severity gateway dependency advisory	P1	Obtain fresh audit and remediate with compatibility evidence
Password format differs from guide/SDS; mixed staff/manager formats	P1	Agree compatibility/alignment and verify role/reset flows
Intermittent sign-in and analytics 503s in prior HAR	P1	Investigate availability; no confirmed cause or security exploit asserted
Production TLS, role grants and exposure unverified	P1	Infrastructure review before external deployment
Build compromise host/organization closure not evidenced	P1	Obtain forensic/remediation evidence; integrity checks alone are insufficient
Real email delivery and encrypted-email interpretation unverified	P2	Provider/domain/inbox checks and accepted security semantics
Direct socket/process-local fanout limits	P2	Approve single-instance boundary or implement shared coordination
Log completeness and 12-month retention not verified	P2	Review telemetry/redaction and establish operational retention
Expiring frontend advisory exception	P2	Remediate or review before 2026-11-14; retain fail-closed gate
Common SRS event envelope differs from MAD domain contracts	P2	Agree correlation/source/envelope mapping with providers

6. Verification and handoff

The test register contains planned normal/negative/security cases mapped to actual test sources. Their current actual-output field remains execution evidence pending. Do not mark these controls passed solely because a related .spec file exists.

Required evidence before final security acceptance: matching CI/audit results, executed authorization/auth/validation cases, a reviewed threat model, production TLS and effective-role assessment, safe/redacted logs, incident closure and a named reviewer decision. Retain scan versions/dates and tested commit identities. Perform active tests only in approved disposable/staging environments.

Milestone conclusion: security mechanisms are present in the built MAD scope, but complete guide section 8 compliance is not established. The approximate 80% project statement is not an authorization to conceal remaining vulnerabilities or claim a security pass. Security acceptance remains Partial / needs review.

References

Guide sections 7, 8.1/8.2 and 10.1; original SDS security chapter and SRS NFR-10/12/13; documents/testing/test-register.md; source files cited per control. Local report and incident references under docs/ must be attached separately because they are Git-ignored. No live credentials, raw sessions or private HAR payloads are attached.